AGH University of Krakow
Faculty of Computer Science, Electronics and Telecommunications
Cybersecurity

Client
Broken Crystals

Web Application Statement of Work

Version 1

Contributors
Mateusz Okoń, Bogdan Khmelnitskiy, Patryk Harasik

Krakow, March 17, 2026

1 The purpose of a penetration test

The aim of this project is to carry out a comprehensive security assessment of the Broken Crystals web application. This initiative was commissioned by the company as part of a strategic effort to perform an overall security review prior to the release of a completely new version of the application. The outcome of the work will be a detailed report containing a description of the identified vulnerabilities, along with their assessed risk level, potential impact, supporting evidence (PoC), and recommendations for remediation.

2 Scope

2.1 In-Scope

- Main web application domain - hxxps[://]brokencrystals[.]com
- Commit hash: 626fd94ae004d600e12338f7f9eee78abaccfcf

The scope of the assessment comprised of:

URL	Description
hxxps[://]brokencrystals[.]com	Home page
hxxps[://]brokencrystals[.]com/marketplace	Marketplace
hxxps[://]brokencrystals[.]com/userprofile	Current user data modification page
hxxps[://]brokencrystals[.]com/chat	Current user private chat
hxxps[://]brokencrystals[.]com/userlogin	User sign in page
hxxps[://]brokencrystals[.]com/newuserlogin	User 2-step sign in page
hxxps[://]brokencrystals[.]com/dashboard	Admin dashboard
hxxps[://]brokencrystals[.]com/adminpage	Admin user catalog
hxxps[://]brokencrystals[.]com/grahiql	Web application tool for writing, validating, and testing GraphQL queries
hxxps[://]brokencrystals[.]com/swagger/*	Broken Crystals REST API
hxxps[://]brokencrystals[.]com/api/*	Broken Crystal APIs

Available endpoints	Description
App	Common operations
Auth	Operations with authentication methods
User	Operations with users (creation, searching)
Files	Operations with files
Subscriptions	Operations with subscriptions
Testimonials	Operations with testimonials
Products	Operations with products
Partners	Operations with partners
Emails	Operations with emails
Chat	Operations with chat

2.2 Environment

Access to the test environment hosted by the client on a provided server via an encrypted tunnel, with pentesters connecting from the IP address 2.2.2.2. The prepared environment reflects the configuration of the production environment, with the exception of the two-factor authentication mechanism, which was disabled for testing purposes, and the user chat module, which was modified. The prepared environment contains mock data. The environment is available throughout the duration of the pentest at the address brokencrystals[.]com within the provided network. Additionally, the environment is network-segmented, and the test environment operates in a separate, isolated network segment. Fragments of code along with documentation will be made available on the Github platform by providing access to the application repository with time-limited access to the indicated files.

2.3 Resources provided by the client

- User account: `user` - standard user account.
- User account: `test` - standard user account.
- User account: `admin` - privileged application-level account with full permissions to manage application configuration.

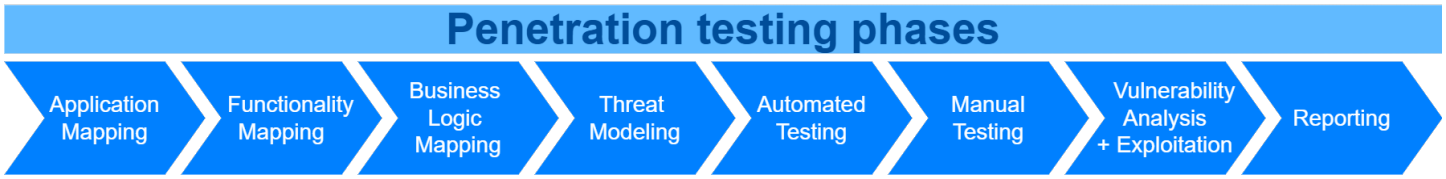
- System architecture diagram
- API documentation
- Fragments of user authentication source code (/src/auth/*)
- Test environment with configuration instructions
- Web application

2.4 Scope of technical testing

- Frontend and backend application testing
- API testing (authorization, permissions, data integrity)
- Input validation testing: XSS, SQLi, parameter manipulation, file upload
- Cookie security testing
- Brute-force resistance testing (user and administrator login)
- Analysis of session and authorization mechanisms
- Testing using vulnerability scanners
- Privilege escalation testing
- Testing for other vulnerabilities defined in OWASP ASVS 5.0.0

3 Methodology - Web Application Security Testing

Type: Gray-box



- **Application Mapping:** This phase focuses on exploring the application to understand its structure and attack surface. It involves navigating through all reachable pages, interacting with available links, submitting forms, and triggering every accessible feature (file uploads, user registration, search modules, etc.). The purpose of this phase is to identify the application's components, overall architecture, technologies, communication flows, and entry points.
- **Functionality Mapping:** Understanding the application's functional capabilities is essential for conducting an effective security assessment. This step aims to catalog all functionalities, classify them by criticality, and identify features that carry the highest impact.
- **Buisness Logic Mapping:** This phase consists of analyzing the rules, workflows, and processes that govern how the application is intended to operate. The goal is to identify decision points, business rules, state transitions, and constraints that attackers could abuse-such as bypassing workflow steps, escalating privileges through misaligned logic, or manipulating multi-stage processes.
- **Threat Modeling:** Threat Modeling involves identifying potential threats, attack vectors, and weaknesses based on the application's architecture, functionality, and business logic. Using methodologies such as STRIDE, this phase prioritizes risks and outlines which areas are most likely to be targeted by attackers.
- **Automated Testing:** This phase consists of running automated security tools to quickly detect common vulnerabilities and misconfigurations.
- **Manual Testing:** Manual testing focuses on thoroughly evaluating the application for vulnerabilities that cannot be reliably detected by automated tools. This includes authentication and authorization testing, session management analysis, access control verification, business logic abuse scenarios, OWASP Top 10 weaknesses, and deep manual inspection of application behavior.
- **Vulerability Analysis + Exploitation:** In this phase, identified findings are validated, analyzed, and-where appropriate-safely exploited to confirm their real impact.
- **Reporting:** The final phase involves preparing a comprehensive report summarizing the assessment. It includes an executive overview, detailed descriptions of all identified vulnerabilities, evidence and proof-of-concept examples, risk ratings (CVSS), and tailored recommendations for remediation.

4 Out-of-scope

- Test network, host, and infrastructure testing.
- Attempt to gain access to the employee and production network.
- Resources unrelated to the Broken Crystals application.
- Extraction of sensitive user data outside the environment.
- Performance, load, and stress testing.
- Configuration changes to the production or test environment.
- Full source code review beyond provided fragments.

5 Schedule

November

S	M	T	W	T	F	S
						01
02	03	04	05	06	07	08
09	10	11	12	13	14	15
16	17	18	19	20	21	22
23	24	25	26	27	28	29
30						

December

S	M	T	W	T	F	S
	01	02	03	04	05	06
07	08	09	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30	31			

January

S	M	T	W	T	F	S
				01	02	03
04	05	06	07	08	09	10
11	12	13	14	15	16	17
18	19	20	21	22	23	24
25	26	27	28	29	30	31

Threat Model

Raport and Recommedietion

Testing, Vulnerability Analysis, Exploitation

6 Points of Contact

In the event that additional information is required, or access to project resources must be granted, the designated points of contact on the client's side are the developers of the Broken Crystals application, available at the following e-mail addresses: anatol1988@gmail[.]com and work[.]gurin@gmail[.]com. The point of contact on the contractor's side is Bogdan Khmelnitskiy, available at the e-mail address: bkhmelnitskiy@student[.]agh[.]edu[.]pl
Project progress will be documented in weekly reports delivered via e-mail. Upon the client's request, it is also possible to provide ongoing status updates.

7 Escalation rules

In the event that a critical security vulnerability is discovered, the team will immediately notify the individuals listed above, and the further course of action will be determined jointly. If necessary, the issue may be escalated to a partner company specializing in vulnerability remediation or mitigation.

* If the Broken Crystals company decides to leave the detected vulnerability unremediated, our team will continue the work according to the schedule and will not be held responsible for any potential consequences resulting from its existence.

* If any personal data that may violate GDPR regulations or any code that was not provided by the client is accidentally discovered, our team will immediately contact the company to report the issue and coordinate appropriate actions.

* If performing a Proof of Concept (PoC) requires actions that go beyond the defined in scope of work , our team will contact the client to discuss the necessity of such activities and to agree on the appropriate course of action before proceeding.

8 Rules of Engagement

- Access outside the scope of the domains and subdomains is not allowed.
- No permanent modification of production data.
- No extraction of real production data outside the test environment.
- Critical vulnerabilities must be reported immediately to the client.
- No changes to system configuration unless explicitly approved.
- No attempts to take over the host, or infrastructure (application only testing).

9 Project results

The result of the work will be the final report:

- a description of the tests performed,
- a risk assessment and classification of the identified vulnerabilities,
- recommendations for remediating or mitigating the discovered security issues.

Signature of Contributors	*Signature of Client*